Rakshak

Team Gabrus

Sheersh Nigam - Team Lead

Akshat Jiwrajka - Developer

Arunangshu Karmakar - Analyst

Simarpreet Singh - Tester

Indian Institute of Technology, Kharagpur

Problem Statement

Why does this problem exist?

The advent of Cryptanalytically Relevant Quantum Computers (CRQCs) threatens the foundational security of current public-key cryptography (like RSA and ECC). Adversaries are already employing "Harvest Now, Decrypt Later" (HNDL) strategies—intercepting and storing encrypted sensitive data today with the intention of decrypting it once quantum computers become powerful enough.

Who is affected by it?

Financial institutions like Punjab National Bank (PNB), government bodies, and enterprise organizations that handle highly sensitive financial, personal, and classified information are directly at risk. Any entity relying on classical cryptographic protocols (e.g., TLS 1.2/1.3 with RSA/ECDSA) to secure data in transit over the internet is vulnerable.

What are the consequences if it remains unresolved?

If left unresolved, a CRQC breach would completely compromise data confidentiality, integrity, and authentication. Passwords, financial transactions, and classified communications captured today will be exposed. Furthermore, the inability to verify digital signatures could lead to severe trust breakdowns, massive regulatory penalties, and catastrophic financial losses.

Proposed Idea

What is your idea?

Rakshak is an automated, enterprise-grade Post-Quantum Cryptography (PQC) scanner and dashboard. It discovers public-facing assets, scans them for their currently deployed cryptographic suites, analyzes their quantum-readiness against NIST standards (FIPS 203, 204, 205), and generates detailed Migration Playbooks.

How does it address the problem?

Rakshak gives organizations immediate visibility into their quantum risk exposure. Instead of relying on manual audits, Rakshak provides an automated Cryptographic Bill of Materials (CBOM) for every asset. By grading assets on a "PQC Ready" to "Critical" scale and providing step-by-step remediation playbooks, it translates abstract quantum threats into actionable, trackable migration workflows.

Why is it innovative or unique?

While conventional vulnerability scanners look for known CVEs or misconfigurations, Rakshak is specifically engineered for the cryptographic landscape. It uses specialized hybrid scanning—combining standard OpenSSL/sslyze testing with a custom OQS (Open Quantum Safe) Docker Probe. This containerized probe is capable of negotiating experimental post-quantum algorithms (like ML-KEM and ML-DSA) that standard operating systems cannot yet speak, allowing Rakshak to accurately verify if an endpoint is truly quantum-safe.

Technical Implementation

Tools, Technologies, or Frameworks:

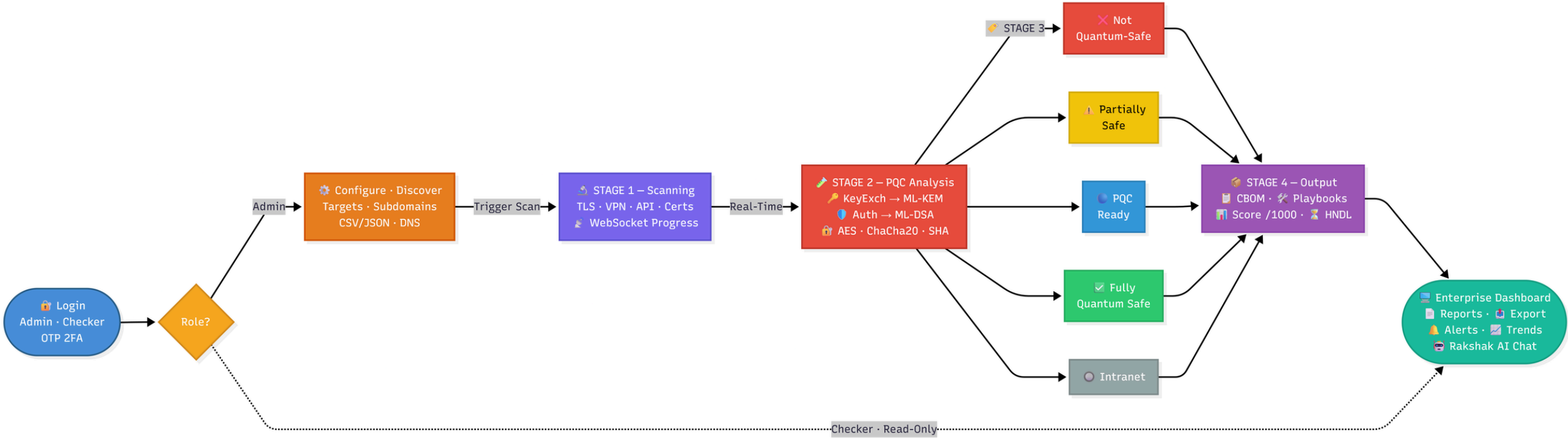
- Backend: FastAPI (Python), SQLAlchemy (SQLite/PostgreSQL)
- Frontend: Bootstrap 5, Jinja2 Templates, Vanilla JS, Chart.js, HTML5 Canvas (for Force-Directed Network Topology)
- Scanning Engine: sslyze (Classical TLS), Open Quantum Safe (OQS) OpenSSL 3 provider inside Docker
- Deployment: Docker, VPS (Virtual Private Server - AWS EC2)
- Reporting: ReportLab (for high-fidelity offline PDF generation)
- AI Integration: Google Gemini Flash API (for Rakshak AI Chat Assistant and domain-aware vulnerability analysis).

Architecture and Dataflow:

- Discovery / Input: The user inputs targets (Domains, IPs, CIDRs) via the UI or bulk CSV/JSON.
- Orchestration: FastAPI processes the request and queues background jobs.
- Classical Scan: sslyze queries the endpoint to extract TLS versions, classical cipher suites, and the X.509 certificate chain.
- Quantum Probe: A subprocess spins up the openquantumsafe/curl Docker container to perform a handshake using advanced algorithms (e.g., -curves p256_kyber768), extracting PQC key exchange and signature data.
- Analysis Engine: The results are parsed by the cert_parser and pqc_classifier, determining if the asset is Elite, Standard, Legacy, or Critical based on NIST matrix definitions.
- Storage & Presentation: Data is saved to the SQLite DB as a CBOM snapshot. The UI polls the WebSocket/API to update the Cyber Rating, Network Topology Graph, and PQC Posture dashboards dynamically.

Technical Implementation

Architecture Diagram and Dataflow



Technical Implementation

Key Features & Technical Differentiators:

- Automated CBOM Generation: Detailed cryptographic inventory mapping Key Exchanges, Authentication, Encryption, and Hashing algorithms per asset.
- Enterprise Cyber Rating: A unified 0-1000 score indicating organizational quantum migration progress, plotted over time to track improvement.
- Actionable Migration Playbooks: Step-by-step, asset-specific remediation guidance highlighting the exact gap (e.g., "Upgrade Certificate Authentication to ML-DSA").
- Interactive CBOM Diffs: Granular comparison between historical snapshots to pinpoint exactly which algorithms, keys, or certs were added or removed between scans.
- Advanced Asset Discovery: Proactive discovery of domains and IPs, visualized through a custom, canvas-based force-directed topology graph utilizing spring-physics for interactive node clustering.
- Real-Time WebSockets: Asynchronous Python (FastAPI/asyncio) background scanning tasks that stream live progress updates to the frontend via WebSockets.
- Role-Based Access Control (RBAC): Secure multi-operator environment distinguishing between Admin and Viewer privileges for managing scans.

Technical Implementation

Key Features & Technical Differentiators:

- Rakshak AI Chat Assistant: Domain-aware conversational AI powered by Google Gemini Flash for interactive vulnerability analysis and step-by-step PQC migration guidance.
- Advanced Subdomain Discovery: Multi-source enumeration engine utilizing CSP header scraping, permutation generation, and DNS liveness verification to automatically expand the asset inventory.
- Two-Factor Authentication (2FA): Mandatory email-based OTP verification securing all dashboard access and administrator logins.
- Weakest-Link Downgrade Rule: Automatically forces a "Critical / Not Quantum-Safe" rating if legacy protocols (e.g., TLS 1.0/1.1) or broken ciphers are detected, preventing false-positive safe ratings regardless of PQC presence.
- Domain-Scoped High-Fidelity Reporting: Secure offline PDF reports enhanced with domain-wise summary sections and detailed subdomain coverage tables.
- Granular Cyber Scoring: The centralized Enterprise Cyber Rating (0-1000) features individual, per-asset cyber scores for precise drill-down analytics.
- Domain-Driven Operations: Streamlined enterprise management featuring hierarchical domain grouping, contextual CBOM snapshot filtering, and cascading bulk asset cleanup.

Impact: Improving Cybersecurity

- **Rakshak** will dramatically accelerate the transition to **quantum-safe** architectures by providing the essential first step: **comprehensive visibility**. It eliminates blind spots in cryptographic deployments.
- It provides a **proactive defense mechanism by identifying vulnerable assets** before quantum computers mature.
- It directly **mitigates the risk of "Harvest Now, Decrypt Later" (HNDL) attacks** by guiding the bank's transition to quantum-safe cryptography.

Benefits & Key Advantages

Who Benefits?

Security Analysts and Auditors, CISOs and Board members, DevOps and IT teams, and ultimately the Bank's customers.

What Benefits?

By automating manual cryptographic audits into minutes of continuous scanning, this solution slashes operational costs while ensuring absolute compliance with upcoming RBI and NIST PQC mandates, effectively shifting your enterprise from reactive firefighting to proactive network immunization.

Feasibility

- **Zero Disruption:** The scanner operates in a strictly read-only, passive mode. It performs TLS handshakes without writing or executing payloads, ensuring zero disruption to live banking services.
- **Software-Only Deployment:** The system operates entirely in software with no specialized hardware required.
- **Cost-Effective:** By leveraging a powerful open-source core alongside the cost-efficient Google Gemini Flash API, the system delivers enterprise-grade security analysis without the burden of heavy licensing or infrastructure fees.

Scalability

- The backend scanning engine is highly concurrent, capable of handling 50+ target endpoints simultaneously without causing severe degradation in dashboard responsiveness.
- The architecture utilizes asynchronous Python (asyncio) and background task queues, allowing it to scan hundreds of IP addresses and domains concurrently.
- The SQLite database can easily be hot-swapped for PostgreSQL for massive enterprise deployments, and the containerized scanning workers can be scaled horizontally across a Kubernetes cluster.

Potential Challenges and Mitigation

Challenge: Network Firewalls (WAF/IPS): Aggressive scanning may be blocked or throttled by enterprise firewalls.
Mitigation: AWS firewall manager has been configured for the server instance such that seamless scanning can be done. This can be further refined when a scan link returns Unkown rating.

Challenge: The scanner initially struggled to detect hybrid keys (mixed classical/PQC layers) and experienced slow scanning speeds due to heavy protocol overhead.
Mitigation: We optimized the pipeline by deploying a concurrent, non-blocking asynchronous architecture for faster throughput, alongside a dual-engine OID parsing mechanism to properly identify and label hybrid states.

Challenge: Firing up Docker containers for the OQS probe per target consumes more memory than raw socket connections.
Mitigation: Future updates will migrate from invoking a Docker container to utilizing a long-running native Python wrapper around liboqs, drastically cutting down overhead.

Prototype and Demo

Prototype: https://rakshak.live

Github Repository:
https://github.com/Team-Gabhrus/rakshak

Demo Link:
https://www.youtube.com/watch?v=iU02nusd_a8

Future Roadmap

Long-Term Enhancements:

- Transforming the current Automated PQC Migration Playbooks into sophisticated, active remediation scripts that possess the autonomy to automatically push and apply critical cipher suite updates across diverse network infrastructure.
- Establishing seamless, direct integration pathways with leading SIEM and SOAR platforms, such as Splunk and QRadar, to facilitate centralized alert routing and unified security orchestration across the entire enterprise.
- Engineering an automated, zero-downtime certificate rotation framework that integrates directly with AWS and Cloudflare environments to eliminate manual intervention and prevent service outages.
- Replace the existing Gemini integration with a secure, on-premise open-source language model to guarantee zero data exfiltration and adhere to strict enterprise compliance.

Conclusion

Why Choose Rakshak?

- **Complete Goal Alignment:** Rakshak doesn’t just address the problem statement—it surgically targets it. We deliver a completely passive, agentless software scanner that automatically discovers public-facing digital assets and rigorously validates their posture against the latest NIST PQC standards (FIPS 203, 204, 205). It evaluates live, real-world TLS handshakes to secure the bank's true perimeter.
- **Beyond Basic Scanning:** Current market tools stop at merely identifying vulnerabilities, leaving security teams with a mountain of disorganized alerts. Rakshak goes several steps further by acting as an end-to-end PQC transition engine. It auto-generates exportable, dynamic Cryptographic Bill of Materials (CBOMs), intelligently categorizes each asset strictly into the required 6-tier classification (e.g., "PQC Ready", "Fully Quantum Safe"), and synthesizes step-by-step IT remediation playbooks. We transform alerts into immediate, actionable fixes.
- **Enterprise-Ready:** Designed from the ground up for massive financial institutions like PNB. Beneath its highly scalable Dockerized architecture lies a centralized Command Center equipped with Role-Based Access Control (RBAC). Crucially, Rakshak bridges the communication gap between deep engineering teams and executive leadership by distilling complex, abstract cryptographic risks into one highly visible, actionable Cyber Health Score (0-1000)—making the daunting quantum transition manageable, quantifiable, and transparent.